

ENCUESTA INTEGRAL CIA TRIAD

Diagnóstico de Madurez en Ciberseguridad: Confidencialidad, Integridad y Disponibilidad

Kit de Evaluación Organizacional • Versión 2025

"Quien responde con sinceridad a esta encuesta ya ha dado el primer paso hacia la resiliencia. Quien la deja en el cajón, probablemente también tiene el plan de respuesta a incidentes en el mismo lugar."

INSTRUCCIONES PARA EL ENCUESTADO

Tiempo estimado de cumplimentación: 45–60 minutos

Perfil destinatario: CISO, CIO, CTO, DPO, Responsable de Seguridad, Director de TI, Responsable de Cumplimiento

Confidencialidad: Las respuestas son anónimas y se tratarán de forma agregada conforme al RGPD

Escala de madurez base (para preguntas con escala Likert):

Nivel	Descripción
1 — Inexistente	No existe ninguna medida, política ni conciencia sobre el aspecto evaluado
2 — Inicial	Existe alguna medida ad hoc, pero sin formalización ni seguimiento sistemático
3 — En desarrollo	Hay política documentada pero su implementación es parcial o inconsistente
4 — Definido	Política implementada, con seguimiento regular y revisión anual
5 — Optimizado	Proceso maduro, medido continuamente, con mejora iterativa y benchmarking externo

BLOQUE 0: PERFIL ORGANIZACIONAL

P0.1 — ¿Cuál es el sector de actividad principal de su organización?

- ☐ Administración Pública (local, autonómica o estatal)
- ☐ Banca y servicios financieros
- ☐ Seguros
- ☐ Salud y ciencias de la vida
- ☐ Energía y utilities
- ☐ Telecomunicaciones y TIC
- ☐ Industria y manufactura
- ☐ Transporte y logística
- ☐ Educación e investigación

- ☐ Comercio y distribución
- ☐ Defensa y seguridad
- ☐ Otro (especifique): ____

P0.2 — ¿Cuántos empleados tiene su organización?

- ☐ Menos de 50 (microempresa)
- ☐ Entre 50 y 250 (pequeña empresa)
- ☐ Entre 251 y 1.000 (mediana empresa)
- ☐ Entre 1.001 y 5.000 (gran empresa)
- ☐ Más de 5.000 (gran corporación o administración)

P0.3 — ¿Cuál es el ámbito geográfico de operación?

- ☐ Local / regional (España)
- ☐ Nacional (España)
- ☐ Europeo (UE/EEE)
- ☐ Internacional (fuera de UE)
- ☐ Global (presencia en múltiples continentes)

P0.4 — ¿Su organización está clasificada como Operador Esencial u Operador de Servicios Digitales bajo la normativa NIS2?

- ☐ Sí, como Operador Esencial
- ☐ Sí, como Operador de Servicios Digitales
- ☐ En proceso de determinación
- ☐ No aplica
- ☐ Desconocemos nuestra clasificación (*esto, señores, ya es un hallazgo en sí mismo*)

P0.5 — ¿Su organización está sujeta al Esquema Nacional de Seguridad (ENS)?

- ☐ Sí, y estamos certificados en nivel Básico
- ☐ Sí, y estamos certificados en nivel Medio
- ☐ Sí, y estamos certificados en nivel Alto
- ☐ Sí, pero aún no tenemos certificación
- ☐ No aplica (sector privado sin contratos públicos)
- ☐ No lo sabemos con certeza

P0.6 — ¿Existe en su organización una figura formal de CISO (Chief Information Security Officer) o equivalente?

- ☐ Sí, con dedicación exclusiva y reporte directo al Consejo / CEO
- ☐ Sí, pero con dedicación parcial o combinado con otras funciones (CIO, CTO...)
- ☐ No existe como figura formal, pero hay un responsable de facto
- ☐ No existe ninguna figura responsable de ciberseguridad como tal
- ☐ Contratamos esta función con un proveedor externo (vCISO)

P0.7 — ¿Cuál es el presupuesto aproximado dedicado a ciberseguridad como porcentaje del presupuesto TI total?

- ☐ Menos del 5%
- ☐ Entre 5% y 9%
- ☐ Entre 10% y 14%
- ☐ Entre 15% y 20%
- ☐ Más del 20%
- ☐ No tenemos esta cifra desglosada (señal de alerta, por favor, tómense nota)

BLOQUE 1: CONFIDENCIALIDAD

"Lo que no debe ser visto, no debe ser accesible"

1.A. CONTROL DE ACCESO E IDENTIDAD

P1.1 — ¿Qué porcentaje de los usuarios con acceso a sistemas críticos tiene habilitada la Autenticación Multifactor (MFA)?

- ☐ Menos del 25% (exposición crítica)
- ☐ Entre 25% y 50% (exposición alta)
- ☐ Entre 51% y 75% (exposición moderada)
- ☐ Entre 76% y 90% (buena cobertura, con lagunas)
- ☐ Más del 90% (cobertura casi completa)
- ☐ 100%, incluidas cuentas privilegiadas y de servicio

P1.2 — ¿Qué tipo de MFA es el predominante en su organización para sistemas de alta criticidad?

- ☐ OTP por SMS (conveniencia máxima, seguridad mínima ante SIM swapping)
- ☐ OTP por aplicación de autenticación (TOTP/HOTP)
- ☐ Token hardware (RSA SecurID, YubiKey tipo OTP)
- ☐ FIDO2 / passkeys / WebAuthn (resistente al phishing)
- ☐ Certificado digital + PIN (PKI)
- ☐ Biometría combinada con otro factor
- ☐ Varios métodos según el nivel de criticidad del sistema

P1.3 — ¿Dispone su organización de un proceso formal de gestión del ciclo de vida de identidades (ILM/IAM)?

- ☐ Sí, con provisión y desprovisión automatizada desde el HRMS
- ☐ Sí, pero el proceso es manual e irregular
- ☐ Parcialmente: tenemos IAM para algunos sistemas, pero no todos
- ☐ No, los accesos se gestionan de forma ad hoc por cada departamento
- ☐ ¿IAM? Tenemos una hoja de Excel compartida (*respuesta válida y honesta*)

P1.4 — ¿Con qué frecuencia se realiza una revisión formal de los privilegios de acceso de todos los usuarios?

- ☐ Continua / en tiempo real (mediante herramientas IGA)
- ☐ Mensual

- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Cuando alguien recuerda que hay que hacerla

P1.5 — ¿Existe una política formal de Gestión de Accesos Privilegiados (PAM)?

- ☐ Sí, con solución PAM tecnológica implementada y auditada
- ☐ Sí, con política documentada pero sin solución tecnológica específica
- ☐ Hay directrices informales, pero sin política formal ni herramienta
- ☐ No existe política PAM
- ☐ Contamos con cuentas de administrador compartidas sin rotación de credenciales (*por favor, pare de leer esto y corrija eso primero*)

P1.6 — ¿Aplica su organización el principio de mínimo privilegio (least privilege) de forma sistemática?

- ☐ Sí, implementado y verificado automáticamente mediante revisiones periódicas
- ☐ Sí, como política declarada, con cumplimiento irregular
- ☐ Solo en sistemas críticos o regulados
- ☐ No formalmente; los accesos tienden a acumularse con el tiempo
- ☐ No aplica este principio de ninguna forma sistemática

1.B. CIFRADO Y PROTECCIÓN DE DATOS

P1.7 — ¿Qué porcentaje de los datos clasificados como sensibles o confidenciales están cifrados en reposo?

- ☐ Menos del 25%
- ☐ Entre 25% y 50%
- ☐ Entre 51% y 75%
- ☐ Entre 76% y 95%
- ☐ Más del 95% / prácticamente el 100%
- ☐ No tenemos un inventario de datos clasificados (lo cual hace que esta pregunta sea filosófica)

P1.8 — ¿Qué algoritmos de cifrado utiliza mayoritariamente para datos en reposo?

- ☐ AES-256 (estándar robusto)
- ☐ AES-128
- ☐ Algoritmos propietarios del proveedor de nube (sin gestión propia de claves)
- ☐ 3DES u otros algoritmos legacy (urgente revisión recomendada)
- ☐ No lo sabemos con certeza
- ☐ Los datos no están cifrados en reposo

P1.9 — ¿Está iniciando o planificando la migración hacia algoritmos de criptografía post-cuántica (PQC)?

- ☐ Sí, hemos iniciado una evaluación formal y roadmap de migración
- ☐ Sí, estamos en fase de piloto con ML-KEM o ML-DSA (estándares NIST FIPS 203/204)

- ☐ Lo conocemos pero aún no hemos priorizado acciones concretas
- ☐ No lo hemos considerado todavía
- ☐ ¿Post-cuántica? Aún tenemos SHA-1 en algunos sistemas (*hay que empezar por algún sitio*)

P1.10 — ¿Dispone su organización de una solución de Prevención de Pérdida de Datos (DLP)?

- ☐ Sí, solución DLP completa (endpoint, red y nube) con políticas activas de bloqueo
- ☐ Sí, pero solo en modo monitorización/alertas, sin bloqueo activo
- ☐ Solución parcial (solo endpoint o solo red, no ambos)
- ☐ No tenemos DLP implementado
- ☐ Dependemos de controles manuales y procedimientos administrativos

P1.11 — ¿Cómo gestiona su organización la exfiltración de datos por parte de empleados o terceros?

- ☐ Mediante DLP, UEBA (análisis de comportamiento) y monitorización de tráfico
- ☐ Solo mediante DLP sin análisis de comportamiento
- ☐ A través de políticas contractuales y NDAs, sin controles técnicos automáticos
- ☐ No tenemos controles específicos para este escenario
- ☐ Confiamos en la buena fe de todos los implicados (*fe admirable, pero auditable*)

1.C. GESTIÓN DE INFORMACIÓN SENSIBLE Y CLASIFICACIÓN

P1.12 — ¿Dispone su organización de un esquema formal de clasificación de la información?

- ☐ Sí, con cuatro o más niveles (por ej.: Público / Interno / Confidencial / Secreto)
- ☐ Sí, con dos o tres niveles básicos
- ☐ Existe en papel pero no se aplica en la práctica diaria
- ☐ No existe clasificación formal de la información
- ☐ Clasificamos todo como "confidencial" para evitar tomar decisiones difíciles

P1.13 — ¿Con qué frecuencia se realiza un inventario o auditoría de activos de información?

- ☐ Continua / automatizada mediante herramientas de descubrimiento de activos
- ☐ Anual como parte de auditoría ISO 27001 o ENS
- ☐ Bienal o irregular
- ☐ Nunca de forma sistemática
- ☐ Tenemos una parte del inventario en una hoja de cálculo que nadie actualiza

1.D. PRIVACIDAD Y GESTIÓN DE SHADOW AI

P1.14 — ¿Ha evaluado su organización el uso de herramientas de IA no sancionadas (Shadow AI) por parte de empleados?

- ☐ Sí, tenemos un inventario actualizado de todas las herramientas IA en uso
- ☐ Hemos hecho una evaluación puntual pero no continua
- ☐ Sabemos que existe pero no lo hemos evaluado formalmente
- ☐ No tenemos visibilidad sobre qué herramientas IA usan los empleados
- ☐ Somos completamente agnósticos al respecto y eso nos genera cierta angustia existencial

P1.15 — ¿Existe una política corporativa que regule el uso de herramientas de Inteligencia Artificial generativa (ChatGPT, Copilot, Gemini, etc.)?

- ☐ Sí, política completa con lista de herramientas permitidas, prohibidas y condicionadas
- ☐ Sí, pero solo cubre las herramientas corporativas oficiales, no el uso personal
- ☐ Hay directrices informales comunicadas por correo electrónico
- ☐ No existe ninguna política al respecto
- ☐ Hemos prohibido todo sin alternativa corporativa (lo que garantiza el uso clandestino)

P1.16 — Valore el nivel de madurez de su organización en la dimensión de CONFIDENCIALIDAD (escala 1-5):

(Ver tabla de referencia al inicio del documento)

- ☐ 1 — Inexistente
- ☐ 2 — Inicial
- ☐ 3 — En desarrollo
- ☐ 4 — Definido
- ☐ 5 — Optimizado

P1.17 — ¿Cuáles son los tres mayores retos de su organización en materia de confidencialidad?

(selección múltiple, máximo 3)

- ☐ Gestión de identidades y accesos en entornos híbridos / multi-nube
- ☐ Protección de datos en dispositivos personales (BYOD)
- ☐ Control del Shadow IT y Shadow AI
- ☐ Cifrado de datos en entornos legados (legacy)
- ☐ Formación y concienciación de empleados
- ☐ Gestión del riesgo de la cadena de suministro (terceros con acceso a datos)
- ☐ Cumplimiento con RGPD / LOPDGDD
- ☐ Protección frente a ataques de phishing dirigido (spear phishing)
- ☐ Migración a criptografía post-cuántica
- ☐ Otro: ____

BLOQUE 2: INTEGRIDAD

"Lo que debe ser exacto, no admite versiones alternativas"

2.A. VERIFICACIÓN Y MONITORIZACIÓN DE INTEGRIDAD

P2.1 — ¿Dispone su organización de herramientas de Monitorización de Integridad de Ficheros (FIM)?

- ☐ Sí, con cobertura superior al 90% de los activos críticos y alertas en tiempo real
- ☐ Sí, con cobertura parcial (menos del 75% de activos críticos)
- ☐ Sí, pero solo en entornos regulados específicos (PCI-DSS, ENS Alto)
- ☐ No, no tenemos FIM implementado
- ☐ Dependemos de las alertas del antivirus para detectar cambios *(el ingenio como sustituto de la inversión)*

P2.2 — ¿Con qué algoritmo de hash se verifican principalmente los archivos críticos del sistema?

- ☐ SHA-256 o SHA-3 (estándar actual recomendado)
- ☐ SHA-1 (en fase de deprecación, requiere migración urgente)
- ☐ MD5 (deprecated, uso solo en contextos no criptográficos)
- ☐ Mediante herramientas propietarias del fabricante (hash interno desconocido)
- ☐ No verificamos la integridad de ficheros mediante hash

P2.3 — ¿Cuál es el tiempo mediano de aplicación de parches para vulnerabilidades críticas (CVSS $\geq$ 9.0)?

- ☐ Menos de 24 horas (política de emergencia activada automáticamente)
- ☐ Entre 1 y 7 días (ciclo de parcheo ágil)
- ☐ Entre 8 y 30 días (ciclo mensual estándar)
- ☐ Entre 31 y 90 días (proceso lento o con dependencias complejas)
- ☐ Más de 90 días (el 28% de organizaciones EU según ENISA 2025, por cierto)
- ☐ No tenemos un proceso de parcheo definido; parcheamos cuando el sistema falla

P2.4 — ¿Cuál es el tiempo mediano de aplicación de parches para dispositivos de borde (edge devices, VPN concentrators, firewalls)?

- ☐ Menos de 7 días
- ☐ Entre 8 y 30 días
- ☐ Entre 31 y 60 días (mediana global es 32 días, según Verizon DBIR 2025)
- ☐ Más de 60 días
- ☐ Solo parcheamos en mantenimientos planificados anuales o bianuales
- ☐ No tenemos inventario actualizado de dispositivos de borde

P2.5 — ¿Dispone de un proceso formal de gestión de vulnerabilidades (VM) con priorización por riesgo?

- ☐ Sí, con herramienta VM automatizada, priorización CVSS/EPSS y SLA de remediación definidos
- ☐ Sí, con escaneos periódicos pero sin SLA formal de remediación
- ☐ Realizamos escaneos puntuales (uno o dos al año) sin seguimiento sistemático
- ☐ Solo realizamos evaluaciones de vulnerabilidades cuando lo exige una auditoría externa
- ☐ No tenemos proceso de gestión de vulnerabilidades

2.B. CADENA DE CUSTODIA Y NO REPUDIO

P2.6 — ¿Qué porcentaje de las transacciones y comunicaciones críticas de su organización están respaldadas por firma digital verificable?

- ☐ Más del 95%
- ☐ Entre 75% y 95%
- ☐ Entre 50% y 74%
- ☐ Menos del 50%
- ☐ Solo las obligadas por normativa (eIDAS, facturación electrónica)
- ☐ No utilizamos firma digital de forma sistemática

P2.7 — ¿Dispone de un sistema de logs centralizado con integridad garantizada (inmutabilidad)?

- ☐ Sí, SIEM con almacenamiento inmutable y firma criptográfica de logs
- ☐ Sí, SIEM centralizado pero sin garantías formales de inmutabilidad
- ☐ Los logs están centralizados pero son modificables (riesgo de manipulación)
- ☐ Los logs están dispersos en los propios sistemas sin centralización
- ☐ ¿Logs? Los sistemas generan eventos, pero nadie los revisa activamente

P2.8 — ¿Cuánto tiempo conserva su organización los registros de auditoría (logs) de sistemas críticos?

- ☐ Más de 24 meses (cumplimiento NIS2/ENS nivel Alto)
- ☐ Entre 12 y 24 meses
- ☐ Entre 6 y 12 meses
- ☐ Menos de 6 meses
- ☐ Hasta que se llena el disco y se sobrescriben automáticamente

P2.9 — ¿Existe un proceso formal de cadena de custodia digital para evidencias forenses?

- ☐ Sí, procedimiento documentado y probado, con personal certificado en forense digital
- ☐ Sí, procedimiento documentado pero sin pruebas periódicas ni personal especializado
- ☐ Existe orientación general, pero sin procedimiento formal
- ☐ No existe proceso de forense digital ni cadena de custodia
- ☐ En caso de incidente, improvisamos con los medios disponibles (*el jazz de la ciberseguridad*)

2.C. INTEGRIDAD EN LA CADENA DE SUMINISTRO

P2.10 — ¿Verifica su organización la integridad del software y los componentes de terceros antes de su instalación en producción?

- ☐ Sí, verificación criptográfica sistemática (hash + firma del fabricante) antes de cualquier instalación
- ☐ Sí, para software crítico, pero no para todos los componentes
- ☐ Solo cuando el proveedor proporciona el hash de forma explícita
- ☐ No realizamos verificación de integridad de software de terceros
- ☐ Instalamos directamente desde el repositorio del fabricante confiando en la cadena de confianza TLS

P2.11 — ¿Dispone su organización de un inventario de Software Bill of Materials (SBOM)?

- ☐ Sí, SBOM completo para todos los sistemas en producción, actualizado automáticamente
- ☐ Sí, para aplicaciones críticas o desarrolladas internamente
- ☐ En proceso de implementación
- ☐ No tenemos SBOM, aunque conocemos el concepto
- ☐ SBOM es un término con el que aún no hemos tenido la debida intimidad conceptual

P2.12 — ¿Cuántos de sus proveedores tecnológicos críticos han sufrido incidentes de seguridad en los últimos 12 meses que hayan impactado a su organización?

- ☐ Ninguno (hasta donde sabemos, con plena conciencia de que "no saber" no equivale a "no ocurrido")
- ☐ 1 proveedor

- ☐ Entre 2 y 5 proveedores
- ☐ Más de 5 proveedores
- ☐ No monitorizamos activamente los incidentes de seguridad de nuestros proveedores

2.D. INTEGRIDAD EN SISTEMAS DE IA Y DATOS

P2.13 — ¿Tiene su organización controles para detectar envenenamiento de datos (data poisoning) en modelos de IA en producción?

- ☐ Sí, con monitorización continua de deriva del modelo y validación de datasets
- ☐ Sí, controles en fase de desarrollo/entrenamiento, pero no en producción
- ☐ No tenemos controles específicos, aunque usamos IA en procesos críticos
- ☐ No utilizamos IA en procesos críticos (o no lo sabemos con certeza)
- ☐ Esto es un área de mejora identificada en nuestra hoja de ruta

P2.14 — ¿Cómo valora el nivel de madurez de su organización en la dimensión de INTEGRIDAD (escala 1-5)?

- ☐ 1 — Inexistente
- ☐ 2 — Inicial
- ☐ 3 — En desarrollo
- ☐ 4 — Definido
- ☐ 5 — Optimizado

P2.15 — ¿Cuáles son los tres mayores retos en materia de integridad? (selección múltiple, máximo 3)

- ☐ Parcheo oportuno de sistemas legacy con criticidad operativa
- ☐ Verificación de integridad de la cadena de suministro de software
- ☐ Gestión de vulnerabilidades en entornos OT/IoT
- ☐ Garantía de integridad en datos procesados por IA
- ☐ Implementación de logs inmutables y cadena de custodia
- ☐ Detección de ataques de espionaje y modificaciones subrepticia de datos
- ☐ Control de cambios en configuraciones de sistemas críticos
- ☐ Migración de algoritmos de hash legacy (SHA-1, MD5)
- ☐ Gestión del riesgo de integridad en entornos multi-nube
- ☐ Otro: ____

BLOQUE 3: DISPONIBILIDAD

"Lo que debe funcionar, no puede permitirse el lujo de descansar"

3.A. CONTINUIDAD Y RECUPERACIÓN

P3.1 — ¿Dispone su organización de un Plan de Continuidad de Negocio (BCP) formalmente documentado?

- ☐ Sí, documentado, probado con ejercicios anuales y actualizado en los últimos 12 meses
- ☐ Sí, documentado y probado, pero con más de 12 meses de antigüedad sin actualizar

- ☐ Sí, documentado, pero nunca ha sido probado en un ejercicio real
- ☐ Existe en versión borrador o parcial
- ☐ No existe BCP formal
- ☐ El BCP es la memoria colectiva de los técnicos de guardia (*táctica válida hasta que cambia el turno*)

P3.2 — ¿Con qué frecuencia se prueban los planes de recuperación ante desastres (DRP)?

- ☐ Más de una vez al año (simulacros semestrales o trimestrales)
- ☐ Anualmente (ejercicio tabletop o prueba técnica)
- ☐ Cada 2-3 años
- ☐ Nunca se ha realizado una prueba formal
- ☐ Solo se comprueba implícitamente cuando ocurre un incidente real (*método de aprendizaje intensivo*)

P3.3 — ¿Cuál es el RTO (Recovery Time Objective) definido para sus sistemas más críticos?

- ☐ Menos de 15 minutos
- ☐ Entre 15 minutos y 1 hora
- ☐ Entre 1 hora y 4 horas
- ☐ Entre 4 horas y 24 horas
- ☐ Más de 24 horas
- ☐ No tenemos RTO formalmente definido para ningún sistema

P3.4 — ¿Cuál es el RPO (Recovery Point Objective) definido para sus datos más críticos?

- ☐ Menos de 1 hora (copias casi en tiempo real)
- ☐ Entre 1 hora y 4 horas
- ☐ Entre 4 horas y 24 horas (backup diario)
- ☐ Más de 24 horas
- ☐ No tenemos RPO formalmente definido
- ☐ El RPO efectivo es "hasta la última copia de seguridad funcional que encontremos"

P3.5 — ¿Con qué frecuencia se realizan y verifican las copias de seguridad de sistemas críticos?

- ☐ Continua / incremental en tiempo real con verificación automática
- ☐ Diaria con verificación periódica (al menos mensual) de restauración
- ☐ Diaria pero sin verificación sistemática de integridad y restaurabilidad
- ☐ Semanal
- ☐ Mensual o menos frecuente
- ☐ Realizamos backups pero no recordamos cuándo fue la última verificación exitosa

P3.6 — ¿Almacena sus copias de seguridad siguiendo la regla 3-2-1 (3 copias, 2 medios diferentes, 1 offsite)?

- ☐ Sí, incluyendo copia air-gapped (desconectada de la red) para resiliencia ante ransomware
- ☐ Sí, cumplimos 3-2-1 pero sin copia air-gapped
- ☐ Parcialmente (2 copias o un único medio)

- ☐ No, todas las copias están en el mismo entorno (incluyendo cloud del mismo proveedor)
- ☐ No, el backup se hace sobre el propio sistema o en unidades conectadas permanentemente

3.B. GESTIÓN DE INCIDENTES Y TIEMPOS DE RESPUESTA

P3.7 — ¿Dispone su organización de un SOC (Security Operations Center) o capacidad equivalente de monitorización continua?

- ☐ SOC propio 24x7x365 con SIEM, SOAR y threat hunting activo
- ☐ SOC gestionado (MDR) con cobertura 24x7
- ☐ SOC propio con horario laboral (8x5), sin cobertura nocturna ni fines de semana
- ☐ Monitorización mediante herramientas, pero sin equipo dedicado
- ☐ No tenemos capacidad de monitorización centralizada
- ☐ Nos enteramos de los incidentes por los propios usuarios (*el helpdesk como sistema de detección*)

P3.8 — ¿Cuál fue el Tiempo Medio de Detección (MTTD) de incidentes de seguridad en su organización en los últimos 12 meses?

- ☐ Menos de 24 horas
- ☐ Entre 1 y 7 días
- ☐ Entre 8 y 30 días
- ☐ Entre 31 y 90 días
- ☐ Más de 90 días (el benchmark global IBM 2025 es 158 días, sigue siendo demasiado)
- ☐ No medimos el MTTD de forma sistemática

P3.9 — ¿Cuál fue el Tiempo Medio de Respuesta/Contención (MTTR/MTTC) en los últimos 12 meses?

- ☐ Menos de 4 horas para incidentes críticos
- ☐ Menos de 24 horas para incidentes críticos
- ☐ Entre 1 y 7 días
- ☐ Entre 8 y 30 días (mediana global para contención: 83 días adicionales según IBM 2025)
- ☐ Más de 30 días
- ☐ No medimos el MTTR de forma sistemática

P3.10 — ¿Ha sufrido su organización un ataque de ransomware en los últimos 24 meses?

- ☐ No, sin incidentes de ransomware conocidos
- ☐ Sí, incidente menor contenido sin impacto operativo significativo
- ☐ Sí, con impacto en la operativa durante menos de 24 horas
- ☐ Sí, con interrupción operativa de 1 a 7 días
- ☐ Sí, con interrupción superior a 7 días (como los municipios de Melilla y Villajoyosa en 2025)
- ☐ Preferimos no responder esta pregunta (*respuesta que, por sí sola, es información valiosa*)

P3.11 — En caso de incidente de ransomware, ¿cuál es la postura formal de su organización respecto al pago del rescate?

- ☐ Política de no pago establecida formalmente, con alternativas técnicas documentadas
- ☐ No pago como postura general, pero sin política formal

- ☐ Evaluación caso por caso sin política definida
- ☐ No tenemos postura definida al respecto
- ☐ Tenemos un seguro cibernético que cubre el pago (verificar condiciones cuidadosamente)

3.C. PROTECCIÓN FRENTE A DDoS Y ALTA DISPONIBILIDAD

P3.12 — ¿Dispone su organización de protección anti-DDoS para sus servicios expuestos a internet?

- ☐ Sí, servicio de scrubbing cloud especializado (Cloudflare, Akamai, AWS Shield Advanced, etc.)
- ☐ Sí, mitigación en el propio ISP o CDN
- ☐ Sí, mediante firewall/IPS con capacidades anti-DDoS limitadas
- ☐ No tenemos protección anti-DDoS específica
- ☐ Solo los servicios críticos tienen protección; el resto está expuesto

P3.13 — ¿Cuál es el nivel de disponibilidad (uptime SLA) comprometido para sus servicios digitales críticos?

- ☐ 99,999% (cinco nueves — menos de 5 min/año de inactividad)
- ☐ 99,99% (cuatro nueves — menos de 52 min/año)
- ☐ 99,9% (tres nueves — menos de 9 horas/año)
- ☐ 99,5% o inferior
- ☐ No tenemos SLA de disponibilidad formalmente definido

P3.14 — ¿Dispone de redundancia geográfica (múltiples centros de datos o regiones cloud) para sistemas críticos?

- ☐ Sí, arquitectura activo-activo en múltiples ubicaciones geográficas
- ☐ Sí, arquitectura activo-pasivo con failover automático
- ☐ Sí, pero el failover es manual y requiere intervención humana
- ☐ No, operamos desde una única ubicación sin redundancia
- ☐ Estamos en proceso de migración a arquitectura redundante

3.D. GESTIÓN DE VULNERABILIDADES EN IoT/OT

P3.15 — ¿Tiene su organización inventariados y gestionados los dispositivos IoT conectados a su red corporativa?

- ☐ Sí, inventario completo con clasificación de riesgo y segmentación de red específica
- ☐ Sí, inventario parcial pero sin segmentación adecuada
- ☐ No, los dispositivos IoT están en la misma red que los sistemas corporativos
- ☐ No tenemos visibilidad del número ni tipo de dispositivos IoT en nuestra red
- ☐ Tenemos una impresora conectada a internet que lleva 3 años sin actualizar (*bienvenidos al IoT real*)

P3.16 — Valore el nivel de madurez de su organización en la dimensión de DISPONIBILIDAD (escala 1-5):

- ☐ 1 — Inexistente
- ☐ 2 — Inicial
- ☐ 3 — En desarrollo

- ☐ 4 — Definido
- ☐ 5 — Optimizado

P3.17 — ¿Cuáles son los tres mayores retos en materia de disponibilidad? (selección múltiple, máximo 3)

- ☐ Protección frente a ransomware con impacto operativo
- ☐ Reducción del MTTD y MTTR
- ☐ Gestión de la continuidad en entornos OT/ICS
- ☐ Protección anti-DDoS de servicios expuestos
- ☐ Redundancia y alta disponibilidad en entornos legacy
- ☐ Gestión de la continuidad en la cadena de suministro de TI
- ☐ Definición y prueba de RTO/RPO en todos los sistemas críticos
- ☐ Cumplimiento con DORA (sector financiero) o NIS2
- ☐ Capacitación del personal para respuesta a incidentes
- ☐ Otro: ____

BLOQUE 4: EXTENSIONES DEL MODELO — AUTENTICIDAD, TRAZABILIDAD Y NO REPUDIO

P4.1 — ¿Tiene su organización implementada una PKI (Infraestructura de Clave Pública) interna o hace uso de servicios de certificación cualificada?

- ☐ PKI interna completa con Autoridad de Certificación propia (CA raíz + CA subordinadas)
- ☐ Uso de servicios de certificación cualificada de terceros (eIDAS QTSPs)
- ☐ Uso de certificados TLS/SSL estándar, sin infraestructura PKI completa
- ☐ No utilizamos PKI de ninguna forma
- ☐ Usamos certificados autofirmados (*válido en localhost, cuestionable en producción*)

P4.2 — ¿Dispone de mecanismos de trazabilidad completa para las acciones de usuarios privilegiados?

- ☐ Sí, grabación de sesiones privilegiadas con almacenamiento inmutable y revisión periódica
- ☐ Sí, registro de comandos/acciones pero sin grabación de sesión completa
- ☐ Solo logs de sistema estándar sin filtrado por privilegio
- ☐ No, las acciones de administradores no tienen trazabilidad diferenciada
- ☐ La trazabilidad es la factura pendiente que tenemos con la auditoría interna

P4.3 — ¿Cumple su organización con los requisitos de eIDAS 2 / firma electrónica cualificada para los procesos que lo requieren?

- ☐ Sí, todos los procesos sujetos a eIDAS 2 utilizan firma cualificada
- ☐ Parcialmente, solo en los procesos obligatorios por normativa
- ☐ En proceso de adecuación al reglamento eIDAS 2
- ☐ No, seguimos usando procedimientos no conformes con eIDAS
- ☐ Estamos evaluando el impacto de eIDAS 2 en nuestros procesos

BLOQUE 5: MARCO NORMATIVO Y CUMPLIMIENTO

P5.1 — ¿Qué marcos de referencia y estándares ha implementado formalmente su organización? (selección múltiple)

- ☐ ISO/IEC 27001:2022 (certificado)
- ☐ ISO/IEC 27001:2022 (en proceso de certificación)
- ☐ ENS (Esquema Nacional de Seguridad) — certificado
- ☐ ENS — en adecuación
- ☐ NIST Cybersecurity Framework 2.0
- ☐ SOC 2 Type II
- ☐ PCI-DSS (sector financiero / comercio)
- ☐ DORA (sector financiero, en vigor desde enero 2025)
- ☐ NIS2 / Anteproyecto LCGC español
- ☐ ISO/IEC 27701 (privacidad)
- ☐ NIST SP 800-53 Rev. 5
- ☐ CIS Controls v8
- ☐ CMMC (sector defensa)
- ☐ Ningún marco formal implementado
- ☐ Otro: ____

P5.2 — ¿Cuántas no conformidades mayores se identificaron en la última auditoría de ciberseguridad?

- ☐ Ninguna
- ☐ Entre 1 y 3
- ☐ Entre 4 y 10
- ☐ Más de 10
- ☐ No hemos tenido auditoría externa en los últimos 24 meses
- ☐ No realizamos auditorías de ciberseguridad

P5.3 — ¿Notifica su organización los incidentes de seguridad a las autoridades competentes (INCIBE-CERT, CCN-CERT, AEPD) dentro de los plazos regulatorios?

- ☐ Sí, siempre dentro de los plazos (24h alerta / 72h notificación bajo NIS2)
- ☐ En la mayoría de los casos, aunque con dificultades en los plazos
- ☐ Solo cuando es explícitamente obligatorio y el incidente es muy grave
- ☐ No tenemos procedimiento de notificación establecido
- ☐ No somos conscientes de los requisitos de notificación que nos aplican (*se recomienda lectura urgente del BOE*)

P5.4 — ¿Tiene su organización contratado un seguro cibernético?

- ☐ Sí, con cobertura para brechas de datos, ransomware, interrupción de negocio y responsabilidad civil
- ☐ Sí, pero con cobertura limitada o con exclusiones significativas
- ☐ En proceso de contratación o renovación
- ☐ No, por razones presupuestarias

- ☐ No, porque consideramos que nuestra postura de seguridad hace innecesario el seguro (*confianza admirable*)

BLOQUE 6: CULTURA, FORMACIÓN Y FACTOR HUMANO

P6.1 — ¿Con qué frecuencia reciben los empleados formación específica en ciberseguridad?

- ☐ Formación continua con módulos mensuales y simulacros periódicos
- ☐ Anual obligatoria para todos los empleados
- ☐ Solo en el onboarding de nuevas incorporaciones
- ☐ Solo para el personal técnico de TI/seguridad
- ☐ No hay formación sistematizada en ciberseguridad

P6.2 — ¿Se realizan simulacros de phishing en su organización?

- ☐ Sí, más de 4 veces al año con análisis de resultados y formación compensatoria
- ☐ Sí, 1-2 veces al año
- ☐ Solo puntualmente, sin programa sistemático
- ☐ No se realizan simulacros de phishing
- ☐ Realizamos simulacros pero no medimos la tasa de clics (*la medición sin métrica es decorativa*)

P6.3 — ¿Ha reportado algún empleado un incidente de seguridad en los últimos 6 meses a través de canales internos?

- ☐ Sí, múltiples reportes, lo que indica una cultura de seguridad activa
- ☐ Sí, algún reporte aislado
- ☐ No, aunque probablemente han ocurrido incidentes no reportados
- ☐ No existe un canal formal de reporte de incidentes
- ☐ Los empleados temen reportar incidentes por miedo a represalias

P6.4 — ¿Cómo calificaría la cultura de ciberseguridad en su organización?

- ☐ Excelente: la ciberseguridad es una responsabilidad compartida en todos los niveles
- ☐ Buena: existe concienciación, aunque con áreas de mejora
- ☐ Regular: los empleados cumplen lo mínimo obligatorio, sin compromiso activo
- ☐ Deficiente: la ciberseguridad se percibe como un obstáculo a la productividad
- ☐ Inexistente: no forma parte de la cultura organizacional en ninguna medida apreciable

BLOQUE 7: TECNOLOGÍA AVANZADA Y TENDENCIAS EMERGENTES

P7.1 — ¿Ha evaluado su organización el impacto de la computación cuántica sobre sus activos criptográficos?

- ☐ Sí, hemos completado un inventario criptográfico completo (crypto-agility assessment)
- ☐ Sí, evaluación parcial centrada en sistemas de alta criticidad
- ☐ Lo hemos discutido a nivel estratégico pero sin acciones concretas
- ☐ No, no está en nuestra agenda actual
- ☐ Creemos que es un problema del futuro lejano (*en ciberseguridad, el futuro llega sin previo aviso*)

P7.2 — ¿Utiliza su organización herramientas de Inteligencia Artificial o Machine Learning para la detección de amenazas?

- ☐ Sí, IA integrada en SIEM/XDR/EDR como capacidad central de detección
- ☐ Sí, herramientas específicas de IA para threat hunting o análisis de comportamiento (UEBA)
- ☐ Sí, pero solo en productos cloud del proveedor sin gestión activa
- ☐ En evaluación o piloto
- ☐ No utilizamos IA en ciberseguridad
- ☐ La IA nos la aplican a nosotros los atacantes, no nosotros a ellos (*dura realidad*)

P7.3 — ¿Ha implementado su organización una arquitectura Zero Trust (nunca confiar, siempre verificar)?

- ☐ Sí, arquitectura Zero Trust completa (identidad, dispositivo, red, aplicación, datos)
- ☐ Sí, en fase de implementación avanzada (más del 60% de los principios implementados)
- ☐ Implementación parcial (microsegmentación o MFA robusto, pero no arquitectura completa)
- ☐ En fase de diseño o planificación
- ☐ No, operamos con un modelo de seguridad perimetral tradicional
- ☐ Zero Trust es un término que usamos en las presentaciones al Consejo con distinta frecuencia que en la realidad técnica

P7.4 — ¿Cómo mide su organización el retorno de la inversión (ROI) de las inversiones en ciberseguridad?

- ☐ Mediante métricas cuantitativas (FAIR, ALE, ROSI) con reportes periódicos al Consejo
- ☐ Mediante indicadores de gestión de riesgos (reducción de exposición, madurez)
- ☐ De forma cualitativa basada en incidentes evitados y cumplimiento normativo
- ☐ No medimos el ROI de la ciberseguridad de forma sistemática
- ☐ El ROI lo medimos en incidentes que no ocurrieron (*métrica difícil de presentar en PowerPoint*)

BLOQUE 8: VALORACIÓN GLOBAL Y PREGUNTAS ABIERTAS

P8.1 — Valoración global de la madurez CIA Triad (escala 1-5 por pilar):

Pilar	1 Inexistente	2 Inicial	3 En desarrollo	4 Definido	5 Optimizado
Confidencialidad	☐	☐	☐	☐	☐
Integridad	☐	☐	☐	☐	☐
Disponibilidad	☐	☐	☐	☐	☐
Autenticidad / Trazabilidad	☐	☐	☐	☐	☐

P8.2 — ¿Cuál es el mayor obstáculo para mejorar la postura de ciberseguridad CIA en su organización? (selección múltiple, máximo 2)

- ☐ Presupuesto insuficiente

- ☐ Falta de talento y personal especializado
- ☐ Resistencia cultural o falta de apoyo directivo
- ☐ Complejidad técnica del entorno (legacy, híbrido, multi-nube)
- ☐ Carga regulatoria excesiva o contradictoria
- ☐ Falta de visibilidad sobre el panorama de amenazas aplicable
- ☐ Dependencia de proveedores sin controles adecuados
- ☐ Velocidad del cambio tecnológico superior a la capacidad de adaptación

P8.3 — ¿Tiene previsto incrementar la inversión en ciberseguridad en los próximos 12 meses?

- ☐ Sí, incremento significativo (>20% respecto al presupuesto actual)
- ☐ Sí, incremento moderado (5–20%)
- ☐ Se mantendrá el presupuesto actual
- ☐ Posible reducción presupuestaria
- ☐ No existe presupuesto específico para ciberseguridad

P8.4 — ¿Participaría su organización en ejercicios de ciberseguridad nacionales o europeos (CyberEurope, ejercicios INCIBE)?

- ☐ Ya participamos activamente
- ☐ Sí, estaríamos interesados
- ☐ Posiblemente, dependiendo de la carga operativa
- ☐ No, por limitaciones de recursos o confidencialidad
- ☐ No éramos conscientes de que existían estas oportunidades

P8.5 — ¿Desea añadir algún comentario, matiz o epifanía ciberseguridad que esta encuesta no haya recogido?

(Campo de texto libre — las respuestas más honestas suelen ser las más valiosas)

DECLARACIÓN DE CONSENTIMIENTO

Al enviar esta encuesta, el respondente declara que las respuestas reflejan su mejor conocimiento sobre la situación actual de la organización, que los datos se tratarán de forma agregada y anonimizada, y que entiende que la honestidad en las respuestas es la única forma de que este ejercicio sirva para algo más que generar un informe que acumule polvo digital en una carpeta de SharePoint.

Fecha de cumplimentación: __

Rol del respondente: __

Departamento: __

Kit CIA Triad Survey v2025 · Basado en: INCIBE Balance 2025, ENISA Threat Landscape 2025, Verizon DBIR 2025, IBM Cost of Data Breach 2025, NIST CSF 2.0, ENS (RD 311/2022), NIS2/LCGC, DORA, ISO/IEC 27001:2022, ITU GCI 2024